

Active reconnaissance & Surface mapping

Кувавiна Софiя

Завдання 1. Індивідуальний аналіз домену

1. Самостійно обрати один цільовий ресурс і виконати всі кроки активної розвідки, які були показані в цьому документі:

- WHOIS для батьківського домену;
- DNS-аналіз dig, nslookup;
- пошук піддоменів Amass або theHarvester;
- визначення технологічного стеку WhatWeb;
- базове сканування портів Nmap.

Цільовим ресурсом обрала testphp.vulnweb.com (батьківський домен vulnweb.com).

1. З команди WHOIS бачимо що домен vulnweb.com зареєстрований у 2010 році, реєстратором є Gandi SAS. Також відображені DNS-сервери, які обслуговують домен

```
(kali㉿kali)-[~]
$ whois vulnweb.com

Domain Name: VULNWEB.COM
Registry Domain ID: 1602006391_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.gandi.net
Registrar URL: http://www.gandi.net
Updated Date: 2025-11-17T09:34:20Z
Creation Date: 2010-06-14T07:50:29Z
Registry Expiry Date: 2027-06-14T07:50:29Z
Registrar: Gandi SAS
Registrar IANA ID: 81
Registrar Abuse Contact Email: abuse@support.gandi.net
Registrar Abuse Contact Phone: +33.170377661
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: NS-105-A.GANDI.NET
Name Server: NS-11-B.GANDI.NET
Name Server: NS-140-C.GANDI.NET
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-02-08T22:04:34Z <<<

For more information on Whois status codes, please visit https://icann.org/epp
```

2. dig vulnweb.com NS показує які DNS-сервери обслуговують домен. З результату видно, що домен vulnweb.com обслуговується трьома DNS-серверами Gandi

```

(kali@kali)-[~]
$ dig vulnweb.com NS

; <<>> DiG 9.20.9-1-Debian <<>> vulnweb.com NS
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 61921
;; flags: qr rd ra; QUERY: 1, ANSWER: 3, AUTHORITY: 0, ADDITIONAL: 5

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 1232
; COOKIE: 6fab00ac23e332ee01000000698909ccb29e5ef6df378217 (good)
;; QUESTION SECTION:
;vulnweb.com.                IN      NS

;; ANSWER SECTION:
vulnweb.com.                5       IN      NS      ns-11-b.gandi.net.
vulnweb.com.                5       IN      NS      ns-140-c.gandi.net.
vulnweb.com.                5       IN      NS      ns-105-a.gandi.net.

;; ADDITIONAL SECTION:
ns-11-b.gandi.net.         5       IN      A       213.167.230.12
ns-105-a.gandi.net.        5       IN      A       173.246.100.106
ns-140-c.gandi.net.        5       IN      A       217.70.187.141
ns-105-a.gandi.net.        5       IN      AAAA    2001:4b98:aaaa::6a

;; Query time: 72 msec
;; SERVER: 192.168.145.2#53(192.168.145.2) (UDP)
;; WHEN: Mon Feb 09 00:10:20 EET 2026
;; MSG SIZE rcvd: 221

```

dig vulnweb.com A показує IP-адресу домену
Домен vulnweb.com відповідає IP-адресі 44.228.249.3

```

(kali@kali)-[~]
$ dig vulnweb.com A

; <<>> DiG 9.20.9-1-Debian <<>> vulnweb.com A
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 11680
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 1232
; COOKIE: 14e970108ca8322801000000698909dafd252d5e96e226e9 (good)
;; QUESTION SECTION:
;vulnweb.com.                IN      A

;; ANSWER SECTION:
vulnweb.com.                5       IN      A       44.228.249.3

;; Query time: 32 msec
;; SERVER: 192.168.145.2#53(192.168.145.2) (UDP)
;; WHEN: Mon Feb 09 00:10:34 EET 2026
;; MSG SIZE rcvd: 84

```

dig vulnweb.com MX показує поштові сервери домену
З результату видно, що для домену налаштовані поштові сервери Google

```

(kali@kali)-[~]
$ dig vulnweb.com MX

; <<>> DiG 9.20.9-1-Debian <<>> vulnweb.com MX
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 55472
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 1232
; COOKIE: c2e15379b34543e601000000698909e575debb2fb5c59a15 (good)
;; QUESTION SECTION:
;vulnweb.com.                IN      MX

;; ANSWER SECTION:
vulnweb.com.                5       IN      MX      10 alt3.aspmx.l.google.com.
vulnweb.com.                5       IN      MX      10 alt1.aspmx.l.google.com.
vulnweb.com.                5       IN      MX      10 aspmx.l.google.com.
vulnweb.com.                5       IN      MX      10 alt2.aspmx.l.google.com.
vulnweb.com.                5       IN      MX      10 alt4.aspmx.l.google.com.

;; Query time: 32 msec
;; SERVER: 192.168.145.2#53(192.168.145.2) (UDP)
;; WHEN: Mon Feb 09 00:10:45 EET 2026
;; MSG SIZE rcvd: 186

```

Команда nslookup підтвердила IP-адресу домену

```

(kali@kali)-[~]
$ nslookup vulnweb.com

Server:                192.168.145.2
Address:               192.168.145.2#53

Non-authoritative answer:
Name:   vulnweb.com
Address: 44.228.249.3

```

3. За допомогою команди amass я зробила пошук піддоменів домену vulnweb.com. У виводі видно що інструмент перевіряє різні джерела та знаходить пов'язані записи домену. Також відображаються DNS-записи та IP-адреси пов'язані з доменом


```

(kali@kali)-[~]
$ amass enum -passive -d vulnweb.com -v

Querying Synapsint for vulnweb.com subdomains
Querying Searchcode for vulnweb.com subdomains
Querying Crtsh for vulnweb.com subdomains
Querying GrepApp for vulnweb.com subdomains
Querying HyperStat for vulnweb.com subdomains
Querying Riddler for vulnweb.com subdomains
Querying AbuseIPDB for vulnweb.com subdomains
Querying Active Crawl for vulnweb.com subdomains
Querying Active DNS for vulnweb.com subdomains
Querying CertSpotter for vulnweb.com subdomains
Querying DNSHistory for vulnweb.com subdomains
Querying Mnemonic for vulnweb.com subdomains
Querying SubdomainCenter for vulnweb.com subdomains
Querying UKWebArchive for vulnweb.com subdomains
Querying CommonCrawl for vulnweb.com subdomains
Querying Arquivo for vulnweb.com subdomains
Querying Baidu for vulnweb.com subdomains
Querying Digitorus for vulnweb.com subdomains
Querying HAW for vulnweb.com subdomains
Querying Bing for vulnweb.com subdomains
Querying Google for vulnweb.com subdomains
Querying PKey for vulnweb.com subdomains
Querying Gists for vulnweb.com subdomains
Querying Sublist3rAPI for vulnweb.com subdomains
Querying LeakIX for vulnweb.com subdomains
Querying SiteDossier for vulnweb.com subdomains
Querying URLScan for vulnweb.com subdomains
Querying Wayback for vulnweb.com subdomains
Querying Brute Forcing for vulnweb.com subdomains
Querying DNSDumpster for vulnweb.com subdomains
Querying Greynoise for vulnweb.com subdomains
Querying HackerOne for vulnweb.com subdomains
Querying Pulsedive for vulnweb.com subdomains
Querying DuckDuckGo for vulnweb.com subdomains
Querying DNS SRV for vulnweb.com subdomains
Querying AnubisDB for vulnweb.com subdomains
Querying Searx for vulnweb.com subdomains
Querying Yahoo for vulnweb.com subdomains

```

```

Querying Ask for vulnweb.com subdomains
Querying Maltiverse for vulnweb.com subdomains
Querying DNSSpy for vulnweb.com subdomains
vulnweb.com (FQDN) → mx_record → alt1.aspmx.l.google.com (FQDN)
vulnweb.com (FQDN) → mx_record → alt4.aspmx.l.google.com (FQDN)
vulnweb.com (FQDN) → mx_record → alt3.aspmx.l.google.com (FQDN)
vulnweb.com (FQDN) → mx_record → alt2.aspmx.l.google.com (FQDN)
vulnweb.com (FQDN) → mx_record → aspmx.l.google.com (FQDN)
vulnweb.com (FQDN) → ns_record → ns-11-b.gandi.net (FQDN)
vulnweb.com (FQDN) → ns_record → ns-140-c.gandi.net (FQDN)
vulnweb.com (FQDN) → ns_record → ns-105-a.gandi.net (FQDN)
alt4.aspmx.l.google.com (FQDN) → a_record → 192.178.163.27 (IPAddress)
alt4.aspmx.l.google.com (FQDN) → aaaa_record → 2a00:1450:4010:c20::1b (IPAddress)
192.178.0.0/15 (Netblock) → contains → 192.178.163.27 (IPAddress)
15169 (ASN) → managed_by → GOOGLE - Google LLC (RIROrganization)
15169 (ASN) → announces → 192.178.0.0/15 (Netblock)
2a00:1450:4010::/48 (Netblock) → contains → 2a00:1450:4010:c20::1b (IPAddress)
15169 (ASN) → announces → 2a00:1450:4010::/48 (Netblock)

The enumeration has finished

```

4. За допомогою WhatWeb визначила, що сайт працює на сервері nginx версії 1.19.0 та використовує PHP 5.6.40. Також у виводі видно IP-адресу та додаткову інформацію, яку сервер передає у відповіді

```
(kali@kali)-[~]
$ whatweb http://testphp.vulnweb.com

http://testphp.vulnweb.com [200 OK] ActiveX[D27CDB6E-AE6D-11cf-9688-444553540000], Adobe-Flash, Country[UNITED STATES][US], Email[wvs@acunetix.com], HTTPServer[nginx/1.19.0], IP[44.228.249.3], Object[http://download.macromedia.com/pub/shockwave/cabs/flash/swflash.cab#version=6,0,29,0][clsid:D27CDB6E-AE6D-11cf-9688-444553540000], PHP[5.6.40-38+ubuntu20.04.1+deb.sury.org+1], Script[text/JavaScript], Title[Home of Acunetix Ar], X-Powered-By[PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1], nginx[1.19.0]
```

З параметром -a 3 я отримала більш детальний результат, але основні технології залишились ті самі

```
(kali@kali)-[~]
$ whatweb -a 3 http://testphp.vulnweb.com

http://testphp.vulnweb.com [200 OK] ActiveX[D27CDB6E-AE6D-11cf-9688-444553540000], Adobe-Flash, Country[UNITED STATES][US], Email[wvs@acunetix.com], HTTPServer[nginx/1.19.0], IP[44.228.249.3], Object[http://download.macromedia.com/pub/shockwave/cabs/flash/swflash.cab#version=6,0,29,0][clsid:D27CDB6E-AE6D-11cf-9688-444553540000], PHP[5.6.40-38+ubuntu20.04.1+deb.sury.org+1], Script[text/JavaScript], Title[Home of Acunetix Ar], X-Powered-By[PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1], nginx[1.19.0]
```

- У результаті сканування видно, що відкритим є порт 80 (HTTP). Інші порти або закриті, або фільтруються. Також видно IP-адресу сервера та зворотний DNS-запис

```
(kali@kali)-[~]
$ nmap testphp.vulnweb.com

Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-10 00:31 EET
Stats: 0:11:22 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 40.76% done; ETC: 00:59 (0:16:31 remaining)
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.0022s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 884 filtered tcp ports (no-response), 115 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 1020.96 seconds
```

Оскільки я побачила що порт 80 відкритий, вирішила додатково перевірити, який саме сервіс на ньому працює. У результаті використовується вебсервер nginx.

```
(kali@kali)-[~]
$ nmap -p 80 -sV testphp.vulnweb.com

Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-10 00:50 EET
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.046s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com

PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.19.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.19 seconds
```

Також бачимо що порт 443 фільтрується

```
(kali㉿kali)-[~]
└─$ nmap -p 80,443 testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-10 00:59 EET
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.024s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com

PORT      STATE      SERVICE
80/tcp    open      http
443/tcp   filtered  https

Nmap done: 1 IP address (1 host up) scanned in 1.85 seconds
```

Завдання 2. Побудова карти поверхні атаки.

На основі власноруч отриманих результатів побудувати карту поверхні атаки у вигляді таблиці:

<i>Endpoint /IP</i>	<i>Service/порт</i>	<i>Технологія</i>	<i>Як було виявлено (інструмент + команда)</i>	<i>Потенційний ризик</i>
vulnweb.com	DNS (NS)	ns-11-b.gandi.net, ns-140-c.gandi.net, ns-105-a.gandi.net	dig vulnweb.com NS	Якщо DNS буде неправильно налаштований, можна перенаправити трафік
vulnweb.com	IP-адреса	44.228.249.3	dig vulnweb.com A / nslookup vulnweb.com	Знаючи IP, можна напряду перевіряти сервер
vulnweb.com	Пошта (MX)	alt1.aspmx.l.google.com та інші Google-сервери	dig vulnweb.com MX	Фішинг
vulnweb.com	Піддомени	DNS-записи	amass enum -passive -d vulnweb.com -v	Кожен піддомен може мати свої вразливості
testphp.vulnweb.com	80 / http	nginx 1.19.0	nmap -p 80 -sV testphp.vulnweb.com	Якщо сервер має вразливості, ними можна скористатись
testphp.vulnweb.com	Web-технологія	PHP 5.6.40	whatweb -a 3 http://testphp.vulnweb.com	Стара версія PHP може мати відомі проблеми безпеки
testphp.vulnweb.com	443 / https	filtered	nmap -p 80,443 testphp.vulnweb.com	Обмежений, але доступний порт

Завдання 3. Короткий аналітичний блок

Написати короткий текст (8–10 речень) з відповідями на питання:

- Який крок активної розвідки виявився найбільш інформативним саме для цього сайту?***
- Які результати неможливо було отримати пасивною розвідкою?***

- *Який сервіс або піддомен ви вважаєте найбільш ризиковим і чому?*
- *Який наступний тип атак був би логічним продовженням (без виконання атак)?*

Відповіді мають спиратись саме на Ваші результати для того сайту, який Ви обрали.

Найбільш інформативним кроком для цього сайту було сканування Nmap та аналіз WhatWeb, тому що там я побачила відкритий порт 80 і технології, які використовуються на сайті такі як nginx та PHP. Пасивна розвідка дала загалом інформацію про домен, DNS та поштові сервери, але вона не показує які порти реально відкриті на сервері. Наприклад, відкритий порт 80 можна було визначити тільки активним скануванням. Також версія nginx підтвердилася через Nmap -sV. Найбільш ризиковим я вважаю сам вебсайт testphp.vulnweb.com так як він використовує стару версію PHP 5.6.40 а також має відкритий HTTP-порт, бо стара версія скоріше за все буде мати відомі вразливості. Логічним продовженням я вважаю тестування самого вебдодатку на наявність типових вебвразливостей (наприклад перевірка форм або параметрів)